Análise da Apresentação, Alta Disponibilidade e FinOps

Startup XYZ — Gestão de Documentos para IA | O que corrigir nos slides, o que mostrar na demo e quanto custa

Equipe: Athos, Jhonatan, Gabriel, Lucas, Rafael

A seção 1 é para quem cuida da apresentação: cada item diz o que está nos slides, o que existe de fato no projeto e como ajustar. As seções 2 a 4 são para quem cuida da demo e da conta AWS.

1. O que não bate entre a apresentação e o projeto

Arquivo analisado: `Arquitetura_V3_Apresentacao_4.html`. Itens com barra vermelha são os que a banca consegue desmentir abrindo o console ou o repositório.

A. Infraestrutura e código

1. Região

Apresentação us-east-1 (Virgínia), 9 vezes, inclusive nos preços.

Real tudo foi criado em **sa-east-1 (São Paulo)**: manual, prints e template.

Por quê a banca vê “sa-east-1” no console durante a demo. Os preços de São Paulo são bem maiores (S3 Standard: US$ 0,0405/GB contra 0,023).

Ajuste trocar a região e usar os preços da seção 4.

2. Ferramenta de IaC

Apresentação “Toda a infraestrutura foi codificada em Terraform” (slide 13 e `main.tf` na aba Código).

Real é **CloudFormation**: `demo-aws/infra/template.base.yaml`, gerado por `build_template.py`. Não existe Terraform no projeto.

Ajuste dizer CloudFormation: nativo, sem arquivo de estado, recria a pilha em ~2 minutos.

3. Testes PyTest (slide 14)

Apresentação “suíte que comprova matematicamente o isolamento”.

Real não há testes no repositório. O teste exibido nem usa a política que gera: só compara duas strings.

Ajuste remover. A prova real de isolamento é a demo com `APP_CHECK=false` (item 11).

4. Código da Lambda (aba Código)

Apresentação `presigner.py`.

Real é `demo-aws/lambda/app.py`. A versão exibida falharia na AWS: a session policy não tem `kms:GenerateDataKey`, então o upload num bucket SSE-KMS é negado. Também não valida tipo nem tamanho e grava tudo como `.pdf`.

Ajuste mostrar o `app.py` (valida PDF/PNG/JPG, limite de 20 MB, 4 rotas).

5. API

Apresentação uma rota, `POST /documents/presigned-url`, e um `openapi.json`.

Real 4 rotas: `POST /upload-url`, `GET /files`, `GET /download-url` e `POST /restore`. Não existe OpenAPI.

6. Tamanho máximo

Apresentação “arquivos de até 50 MB”.

Real **20 MB**, imposto pelo `content-length-range` da URL assinada.

7. Nome original nos metadados

Real o código não grava o nome original. Remover a frase.

8. “Arquitetura Event-Driven”

Real não há nenhum evento ou EventBridge implementado. Remover o termo.

B. Erros técnicos de segurança

9. “HMAC Tampering” no JWT

Real o Cognito assina com **RS256** (assimétrico: chave privada e chave pública). HMAC usa chave compartilhada. O próprio token de exemplo da apresentação começa com `{"alg":"RS256"}`.

Ajuste “adulteração de assinatura RS256”: o API Gateway confere a assinatura com a chave pública do Cognito (JWKS).

10. Path traversal “bloqueado pelo STS com 403”

Real o motivo está errado. O S3 não interpreta `..`: `usuario-123/../usuario-456/x` é só um nome literal **dentro** da pasta do usuário 123, e a política até permitiria.

Ajuste “o ataque não funciona porque no S3 a chave é literal e nunca sai do prefixo do usuário”.

11. “A claim sub elimina IDOR”

Real o `sub` impede escolher a pasta no upload. No download a defesa tem duas camadas: a Lambda recusa a chave alheia e, mesmo com bug na Lambda (`APP_CHECK=false`), a credencial do STS não alcança outra pasta.

Ajuste essa demonstração é o ponto mais forte do projeto e não aparece na apresentação. Deve entrar.

12. “TLS 1.2+ obrigatório” (pergunta 5 da banca)

Real o bucket exige TLS (`aws:SecureTransport`), mas não fixa a versão.

Ajuste dizer “TLS obrigatório”.

C. Antimalware: slide 11 e passo 7

13. GuardDuty + EventBridge + Lambda de Resposta + Bucket de Ameaças

Real nada disso existe. O template tem só o parâmetro opcional `EnforceMalwareScan`, desligado por padrão, que faz o app ler apenas arquivos marcados como limpos.

Contradição o passo 7 “destrói o arquivo em todas as versões”, mas a regra central do case é **nunca apagar**. A política do bucket nega `DeleteObjectVersion` para todos menos o root: a Lambda de Resposta seria bloqueada pelo próprio projeto.

Risco se o GuardDuty der falso positivo, o documento legítimo do cliente some para sempre.

Exageros “cada incidente deixa o sistema mais esperto”: o hash só reconhece o arquivo idêntico, e nada consulta esse banco. A simulação usa `.exe`, que a API real recusa.

Ajuste mover para “Evolução”, com **quarentena com prazo** em vez de destruição.

D. Custos (slides 12 e 15, calculadora FinOps)

14. “95,8% de economia contra uma arquitetura legada de ~US$ 450/mês”

Real o valor de US$ 450 foi inventado. A fórmula no código é `450 + docs/1000 × 0,50`, sem fonte.

Ajuste comparar com alternativas reais em São Paulo: 2 EC2 t4g.small + ALB ≈ **US$ 80/mês**; Fargate ≈ **US$ 72/mês**; camada serverless do projeto ≈ **US$ 2,50/mês**. Sem lifecycle, o armazenamento custaria US$ 73,69/mês no 3º ano, contra US$ 35,47 com lifecycle (−52%).

15. “Custo total ~US$ 18,78/mês”

Real em São Paulo, com a configuração atual: **~US$ 26/mês no 1º ano e ~US$ 35/mês no 3º**. O GuardDuty, que a apresentação diz estar ligado, soma **+US$ 20,66/mês** e seria o maior item da conta.

16. “Deep Archive: −95%”

Real em São Paulo vai de US$ 0,0405 para US$ 0,0032 por GB: **−92%**. Os 95% são de Virgínia.

E. Estrutura exigida pelo guia oficial

17. Slides que faltam

Faltam tabela “requisito × como foi atendido” (slide 8 do guia), Resiliência (10), Backup e Recuperação (13), Demonstração (14, trocada por “Testes PyTest”), requisitos funcionais e não funcionais separados (3) e alternativas consideradas (7).

18. Capa

Ajuste colocar os nomes da equipe; o guia exige.

19. Notas do orador

Ajuste estão para 4 alunos em 15 min. A equipe tem 5, e o roteiro v2 prevê ~13,5 min.

20. Slide final

Ajuste trocar “Projeto TCC Concluído com Sucesso!” por problema → solução → benefícios → próximos passos.

2. Alta disponibilidade e elasticidade: o que mudar no projeto

O argumento base

Num projeto serverless não existe servidor para derrubar: Cognito, API Gateway, Lambda e S3 já rodam em várias zonas de disponibilidade. Pelos SLAs contratuais (Lambda 99,95%, API Gateway 99,95%, Cognito 99,9%, S3 99,9%), a disponibilidade composta fica em torno de **99,7%** sem configuração extra. O que falta é **tornar isso visível**.

Elasticidade

Mudança	O que a banca vê	Custo
Script de teste de carga (`demo-aws/carga/teste_carga.py`): login no Cognito e 1.000 pedidos de `/upload-url`, 50 em paralelo. Mostra latência p50/p95 e contagem de 200 e 429.	No dashboard, a concorrência da Lambda sobe de 1 para dezenas e volta a 0, com latência estável e sem erros.	~US$ 0,003 por rodada
Gráfico `ConcurrentExecutions` no dashboard (hoje não existe).	A curva de escala em tempo real.	Grátis
Throttling como parâmetro da pilha (hoje fixo em 10 req/s, rajada de 20).	Rodada 1, limite baixo: 429 barrados na borda, sem custo de Lambda (“freio de custo”). Rodada 2: sobe o limite (update de ~1 min) e a carga passa toda.	Grátis

Antes da demo

Em Service Quotas, conferir o limite de “Concurrent executions” da Lambda. Contas novas às vezes vêm com apenas 10, e com esse limite o teste de carga falha.

Números úteis para a banca: média de 50 mil por mês ≈ **1,2 documento por minuto**. Cada prefixo do S3 aguenta 3.500 PUT/s e há um prefixo por usuário, então a capacidade cresce com o número de clientes. O gargalo real a monitorar é a cota de login do Cognito.

Alta disponibilidade e recuperação

Mudança	O que a banca vê	Custo
Variável `FAULT_RATE` na Lambda (mesmo padrão do `APP_CHECK`), que faz X% das chamadas falharem, mais **retry com backoff** no `index.html`.	Com 50% de falha, o alarme dispara e o e-mail chega, mas o usuário completa o upload ("tentativa 1 falhou, 2 OK").	Grátis
Versão profissional do mesmo teste: **AWS Fault Injection Service** com ação de erro na Lambda.	O mesmo resultado, com ferramenta de caos de mercado.	Centavos por teste
Replicação entre regiões (CRR) para um bucket em us-east-1, gravando direto em Deep Archive.	Upload em São Paulo e o arquivo aparece em Virgínia: DR regional funcionando.	~US$ 9/mês (pesa a transferência SP→EUA, US$ 0,138/GB)
Restauração de versão pelo console ("Mostrar versões").	Arquivo sobrescrito e a versão anterior volta: proteção contra erro humano e ransomware.	Grátis
`DeletionPolicy: Retain` no bucket e na chave KMS.	Apaga a pilha, recria em ~2 min e os dados continuam lá: RTO medido ao vivo.	Grátis

Achado real no template

Hoje o template **não tem** `DeletionPolicy`. Se alguém excluir a pilha, a chave KMS entra em exclusão agendada e, quando for apagada, **todos os documentos ficam ilegíveis para sempre**, mesmo com o bucket preservado. Para a demo, isso pode virar um parâmetro.

Recomendação

Teste de carga com throttling parametrizado, `FAULT_RATE` com retry e `DeletionPolicy`: é barato, roda ao vivo e responde direto ao comentário do professor. A replicação entre regiões fica como opcional, porque custa todo mês.

3. Serviços alternativos e por que não foram usados

Preços de São Paulo (sa-east-1).

Em uso	Alternativa	Por que não
Cognito	Auth0/Okta, Keycloak em EC2, IAM Identity Center	10 mil usuários ativos/mês grátis e integração nativa com o autorizador JWT. Auth0 cobra por usuário e guarda os dados fora da AWS. Keycloak exige servidor. Identity Center é para funcionários, não clientes.

Em uso	Alternativa	Por que não
API Gateway HTTP API	REST API	US$ 4,25 contra **US$ 1,59** por milhão. A REST traz WAF, cache e *usage plans*; vale como evolução, pois usage plans permitem cobrar planos por cliente.
	Lambda Function URL	Grátis, mas sem autorizador JWT e sem throttling por rota: a segurança teria que ser escrita no código.
	ALB	~US$ 25/mês fixos mesmo sem uso.
Lambda	EC2 (2 instâncias + ALB)	~**US$ 80/mês** contra ~US$ 0,30 da Lambda. Com 1,2 req/min o servidor fica ocioso mais de 99% do tempo, e ainda exige patch e escala.
	ECS Fargate	~**US$ 72/mês** com 2 tarefas para alta disponibilidade.
STS + session policy	Cognito Identity Pool	O navegador receberia credenciais AWS direto: superfície de ataque maior e sem como impor tipo e tamanho de arquivo.
	S3 Access Grants	Feito para esse caso, mas cobra US$ 0,03 por mil pedidos (~US$ 6/mês). O STS é grátis.
	Access Point ou bucket por cliente	Limite de quantidade e uma política por cliente para gerenciar. Um bucket com prefixos escala sem isso.
	ABAC com *session tags*	Equivalente e grátis. Resposta honesta para a banca: “seria uma alternativa válida”.
S3 Standard	EFS, DynamoDB, RDS	EFS exige VPC e é várias vezes mais caro; DynamoDB limita cada item a 400 KB; banco de dados não é lugar de arquivo.
Deep Archive	Glacier Flexible	US$ 0,00765/GB, 2,4 vezes o Deep Archive. A vantagem é restaurar em minutos ou horas.
	Glacier Instant / Intelligent-Tiering	Não substituem, complementam. Ver alavanca nº 1 na seção 4.
KMS com chave própria	SSE-S3 (grátis)	Com chave própria há auditoria no CloudTrail, controle e revogação pela política da chave. Custa US$ 1/mês, e o Bucket Key zera quase todas as chamadas.
GuardDuty (opcional)	ClamAV numa Lambda	Mais barato em volume, mas vocês mantêm as assinaturas de vírus e o código. O GuardDuty é gerenciado.
CloudFormation	Terraform, CDK, SAM	Nativo e grátis, sem arquivo de estado. Terraform faz sentido com várias nuvens; o SAM simplificaria a parte da Lambda.
sa-east-1	us-east-1	A pilha sairia ~45% mais barata, mas: dados de clientes brasileiros no Brasil (LGPD, transferência internacional), menor latência e “dados no Brasil” como argumento de venda.

4. FinOps: o argumento de venda

Premissas

Preços da AWS Price List API (publicação de 28/09/2026), região sa-east-1. 50 mil documentos por mês, 1 MB em média (~48,8 GB/mês), ~4 chamadas de API por documento, Lambda de 256 MB com ~300 ms. Valores em dólar, sem descontar a camada gratuita.

Quanto custa hoje (configuração atual)

Item / mês	1º ano (mês 12)	3º ano (mês 36)
S3 Standard (últimos 12 meses, ~586 GB)	US$ 23,73	US$ 23,73
Deep Archive (histórico) + custo fixo por objeto	—	US$ 4,24
Transições do lifecycle (US$ 0,10 por mil)	—	US$ 5,00
API Gateway + Lambda + PUTs + KMS + CloudWatch	US$ 2,50	US$ 2,50
Total	**~US$ 26**	**~US$ 35**
+ GuardDuty (opcional)	+US$ 20,66	+US$ 20,66

- **O S3 Standard é 67% da conta.** Lambda e API somam centavos: o custo está no primeiro ano de armazenamento.
- **Em São Paulo, mover para o Deep Archive custa mais que guardar nele** (US$ 5,00 em transições contra US$ 3,75 de armazenamento).
- **O GuardDuty custaria mais que toda a infraestrutura.** Por isso deve ser vendido como adicional.

Cenários de armazenamento (alavanca nº 1)

Cenário (total/mês)	Mês 12	Mês 24	Mês 36	Acumulado 3 anos
A. Tudo em Standard (sem lifecycle)	26,23	49,96	73,69	US$ 1.407
B. Atual: Standard por 365 dias → Deep Archive	26,23	33,35	35,47	US$ 987
C. 30 dias Standard → Glacier Instant → Deep Archive aos 365	**9,94**	**17,06**	**19,18**	**US$ 504**
D. Intelligent-Tiering, arquivando no Deep Archive	11,79	15,41	19,02	US$ 480

Mudar uma regra do lifecycle corta ~49% do custo em 3 anos. O cliente lê o documento nos primeiros dias, quando a IA extrai as informações; depois o acesso é raro, e manter o arquivo um ano inteiro em Standard é desperdício. No cenário C, ler um arquivo no Glacier Instant custa US$ 0,03/GB, mas continua em milissegundos, sem restore. O cenário D se ajusta sozinho e não cobra leitura, mas cobra US$ 0,0025 por mil objetos por mês de monitoramento.

Outras alavancas (mudanças no template)

- **Filtro de tamanho no lifecycle** (`ObjectSizeGreaterThan`): um arquivo de 1 MB paga a transição para o Deep Archive em 2,8 meses; um de 128 KB leva 24 meses; um de 64 KB, 4,5 anos. Arquivar só acima de ~256 KB.
- **Tags de custo** (`Projeto=xyz-docs`) em todos os recursos e **Cost Anomaly Detection** (grátis). O template já tem Budget, mas não tem tags.
- **Custo por cliente (showback)**: S3 Inventory + Athena somam os GB por prefixo de cliente por menos de US$ 0,01/mês e permitem faturar pelo uso real.
- **Plano do Cognito**: confirmar se o user pool está no **Lite** (US$ 0,0055 por usuário ativo depois dos 10 mil grátis) e não no **Essentials** (US$ 0,015).

Armadilhas para antecipar à banca

- **Transferência de saída de dados é o custo escondido**: US$ 0,15/GB para a internet em São Paulo, depois de 100 GB grátis por mês. Treinar a IA em outra região sai caro: ler 3 anos de histórico (1,76 TB) de Virgínia custaria ~US$ 243 só em transferência. Regra: processar na mesma região.
- **Restaurar o histórico é barato** se não for urgente: modo Bulk (até 48 h) a US$ 0,008/GB. Um ano inteiro de documentos sai por menos de US$ 5.
- **Logs do CloudWatch** custam US$ 0,90/GB em São Paulo. A retenção de 30 dias já está configurada.

Como vender: custo unitário e planos

Indicador	Valor
Custo de infraestrutura por mil documentos novos/mês (hoje)	US$ 0,71
Mesmo indicador no cenário C	**US$ 0,38**
Volume 10 vezes maior (500 mil/mês), cenário C, 3º ano	US$ 178/mês
Só a computação de uma arquitetura tradicional com alta disponibilidade	US$ 72–80/mês

O custo cresce de forma linear, sem degraus de servidor, e o custo fixo sem uso é praticamente zero. Os planos podem seguir os adicionais, cada um com custo unitário conhecido:

- **Básico**: isolamento, criptografia e histórico.
- **Pro**: + antimalware com GuardDuty (~US$ 0,41 por mil documentos).
- **Enterprise**: + cópia em outra região (~US$ 0,19 por mil documentos de 1 MB) e Object Lock.

Assim o preço acompanha o custo, e cada cliente paga pelo nível de segurança que quer.